habitID — Passive Behavioural Identity Scoring for Indian Digital KYC

One-page project report | React 19 + TypeScript, fully on-device, zero backend

Name: Pranav Prashant Shewale | **Registration Number:** 24BCE1226

1. DATASET DESCRIPTION

Source. No public dataset exists for Indian KYC behavioural biometrics, and the system is privacy-by-design (no data leaves the device), so the evaluation set is a **synthetic, labelled corpus of 2,000 KYC sessions** generated by scripts/simulate.ts with a fixed seed and scored by the production engine (src/services/scoringEngine.ts) without modification.

Size & classes. 1,000 genuine sessions + 1,000 fraud sessions across four archetypes (250 each): scripted bot, SIM-swap mule, OTP-farm/paste-in, and fake identity.

Features (per session). Keystroke events (down/up timestamps, hold time, inter-key flight time); pointer/accelerometer motion samples (velocity magnitude); OTP start/completion timestamps; phone MSISDN; 12-digit Aadhaar number.

Preprocessing. Flight-time outlier filter (keep 0 < f < 2000 ms); minimum-sample gates (<4 keystrokes or <5 motion samples fall back to a neutral prior); mouse events throttled to ~60 Hz; phone stripped of non-digits and the +91 prefix; Aadhaar stripped of spaces/dashes. Derived features: coefficient of variation (CV = σ/μ) of flight times, words-per-minute, motion-velocity CV, OTP latency in seconds, 4-digit MSISDN prefix. No scaling or encoding is needed because the model is rule-based.

2. PROBLEM STATEMENT

SMS-OTP verification proves that a device received a message, not that a real, legitimate person is completing the flow. SIM-swap fraud, OTP farming and scripted account creation all defeat it. The goal is a zero-friction, on-device trust layer that scores how a user behaves during a standard 4-screen KYC flow (Name/Phone → Aadhaar → OTP → Score) and outputs a 0–100 score with a VERIFIED / REVIEW / SUSPICIOUS verdict, without any server call or data egress (DPDP Act 2023 aligned).

3. METHODOLOGY

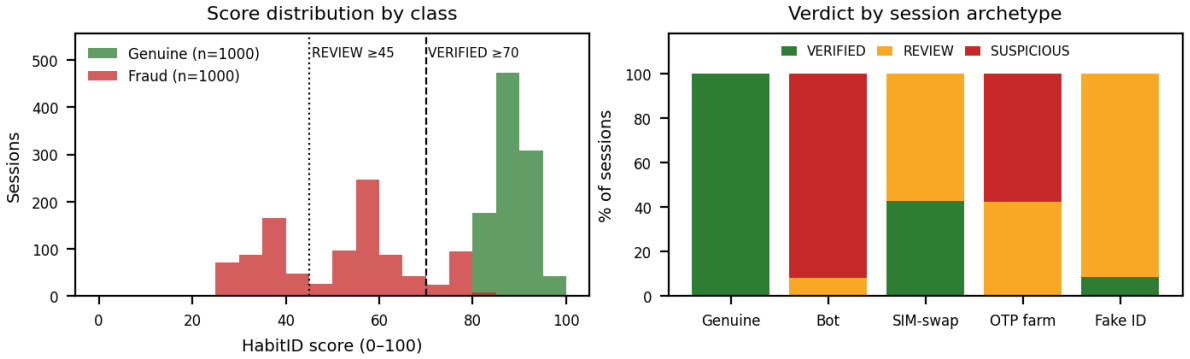
Model. A deterministic, expert-weighted additive fusion of six independent signals (weights sum to 100). Each signal is explained by a per-signal score, risk tier (low/medium/high) and a human-readable reason.

Signal (weight)	Feature	Scoring rule (from source)
Typing rhythm (25)	CV of inter-key flight time × WPM gate	CV 0.2–1.0 → 1.0; CV<0.05 → 0.1 (bot); CV>2 → 0.2; linear taper otherwise. WPM>200 → ×0.4
Tilt / motion (20)	CV of pointer or accelerometer velocity	ratio = max(0, 1 − CV/3); accelerometer on mobile, mouse proxy on desktop
Aadhaar check (20)	Verhoeff check digit (D5 dihedral group)	Binary: 20 if 12 digits, not starting 0/1, and check digit valid
OTP response (15)	Seconds from OTP shown to correct entry	<2 s → 2 (automation); 2–5 s → 8; 5–30 s → 15→8 linear; 30–60 s → 7; >60 s → 5
SIM age (10)	4-digit MSISDN prefix lookup (52 blocks)	vintage 10 · mature 7 · moderate 5 · recent 2 · unknown 4
Phone format (10)	Regex ^[6-9]\d{9}$	Binary 10 / 0

Decision. total = Σ signal scores, clamped 0–100; verdict = VERIFIED (≥70), REVIEW (45–69), SUSPICIOUS (<45). For binary metrics below, VERIFIED = accept, anything else = flag.

4. RESULTS & INSIGHTS

Accuracy	Precision (fraud)	Recall (fraud)	F1	ROC-AUC	FP / FN	Mean score G / F	Latency
93.5%	100.0%	87.1%	0.931	0.999	0 / 129	88.2 / 51.2	<1 ms



- **Zero false positives:** all 1,000 genuine sessions were VERIFIED (mean 88.2), so the layer adds no friction for legitimate users.
- **Bots and OTP farms are caught outright:** 0% of scripted bots or paste-in sessions reached VERIFIED; 92% of bots were SUSPICIOUS. Near-zero flight-time variance and sub-2 s OTP entry are the dominant tells.
- **SIM-swap mules are the weak spot:** 43% were VERIFIED because their typing and motion are genuinely human; only SIM-age and OTP latency penalise them. This archetype drives all 129 misses and caps recall at 87.1%.
- **Signal informativeness:** Aadhaar (20 vs 4.8), typing (25 vs 14.9) and SIM age (8.1 vs 3) separate the classes; motion (15.2 vs 14.3) is nearly uninformative and its 20-pt weight should be reduced or re-tuned. ~10% of random 12-digit numbers pass Verhoeff by chance, which explains the 22 fake-identity sessions that slipped through.

5. NOVELTY

- **Fully passive & fully on-device:** every signal is a side-effect of steps the user already performs; nothing is enrolled, uploaded or stored — compliance is achieved by construction rather than by policy.
- **OTP response latency as a fraud signal:** a piecewise human-reaction curve (5–30 s sweet spot) turns the OTP step itself into a behavioural probe, penalising both automation (<2 s) and relayed/assisted entry (>60 s).
- **MSISDN prefix → subscriber-tenure heuristic:** an open, offline approximation of operator SIM-age data, directly targeting SIM-swap risk.
- **Real Verhoeff validation + explainability by design:** true UIDAI check-digit maths rather than a length check, and a transparent additive score where every point is attributable to a named signal with a plain-language reason — no black-box model, no SHAP needed.